

VULNERABILITY ASSESSMENT REPORT

Metasploitable 2 — Full Nmap Analysis

Target IP	192.168.126.3 (Metasploitable 2)
Tools Used	Nmap 7.99 — Service Scan / Vuln Scripts / Full Port Scan
Date	2026-04-25
Environment	Isolated VirtualBox lab — Host-only network
Open Ports	30 open TCP ports discovered
Critical CVEs	CVE-2011-2523 · CVE-2014-3566 · CVE-2015-4000 · CVE-2014-0224
Analyst	Kareem — Uneeq Interns Cybersecurity Program

1. EXECUTIVE SUMMARY

A comprehensive vulnerability assessment was performed against Metasploitable 2 (192.168.126.3), a deliberately vulnerable virtual machine, within an isolated VirtualBox lab environment. Three Nmap scans were executed: a service version scan, a vulnerability script scan, and a full 65,535-port scan.

Key findings at a glance:

- **30 open TCP ports** discovered across all scans
- **23 services** identified in the service scan — many critically outdated
- **1 CRITICAL exploitable backdoor** — vsftpd 2.3.4 (CVE-2011-2523) confirmed exploitable with root shell
- **4 HIGH severity CVEs** including SSL POODLE, Logjam, CCS Injection, and RMI RCE
- **Multiple web vulnerabilities** — CSRF, Slowloris DoS, exposed admin panels, phpMyAdmin
- **Trojaned IRC daemon** (UnrealIRCd backdoor) detected on port 6667

2. SCOPE

- **Target:** Single host — 192.168.126.3 (Metasploitable 2 VM)
- **Network:** VirtualBox Host-only isolated network — no internet exposure
- **Scan Types:** TCP service scan (-sV), vulnerability scripts (--script vuln), full port scan (-p-)
- **Authorization:** Authorized lab exercise — intentionally vulnerable target
- **Exclusions:** UDP ports not scanned; no active exploitation performed beyond Nmap scripts

3. FINDINGS

3.1 — Service Version Scan Results

Port	Service	Version Detected	Severity
21/tcp	FTP	vsftpd 2.3.4	CRITICAL

Port	Service	Version Detected	Severity
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	HIGH
23/tcp	Telnet	Linux telnetd	CRITICAL
25/tcp	SMTP	Postfix smtpd	MEDIUM
53/tcp	DNS	ISC BIND 9.4.2	MEDIUM
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2	HIGH
111/tcp	RPCbind	2 (RPC #100000)	MEDIUM
139/tcp	NetBIOS	Samba smbd 3.X–4.X	HIGH
445/tcp	SMB	Samba smbd 3.X–4.X	HIGH
512/tcp	exec	netkit-rsh rexecd	HIGH
513/tcp	login	OpenBSD rlogind	HIGH
514/tcp	shell	Netkit rshd	HIGH
1099/tcp	Java RMI	GNU Classpath grmiregistry	HIGH
1524/tcp	Bindshell	Metasploitable root shell	CRITICAL
2049/tcp	NFS	2-4 (RPC #100003)	HIGH
2121/tcp	FTP	ProFTPD 1.3.1	MEDIUM
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5	HIGH
5432/tcp	PostgreSQL	PostgreSQL 8.3.0–8.3.7	MEDIUM
5900/tcp	VNC	VNC protocol 3.3	HIGH
6000/tcp	X11	X11 (access denied)	MEDIUM
6667/tcp	IRC	UnrealIRCd (trojaned)	CRITICAL
8009/tcp	AJP	Apache Jserv Protocol v1.3	MEDIUM
8180/tcp	HTTP	Apache Tomcat/Coyote JSP 1.1	HIGH

3.2 — Confirmed Vulnerabilities & CVEs

Port	CVE / ID	Severity	Description
21/tcp	CVE-2011-2523	CRITICAL	vsftpd 2.3.4 backdoor — confirmed exploitable. Shell command returned uid=0(root). Full system compromise possible.
25/tcp	CVE-2014-3566	HIGH	SSL POODLE — SSLv3 CBC padding oracle allows MitM attacker to decrypt traffic.
25/tcp	CVE-2015-4000	HIGH	Logjam — TLS DHE_EXPORT downgrade attack allows MitM to break encryption to 512-bit.
25/tcp	DH Weak Group	HIGH	Anonymous Diffie-Hellman Key Exchange — no authentication, vulnerable to active MitM.
80/tcp	CVE-2007-6750	HIGH	Slowloris DoS — Apache keeps connections open via partial HTTP requests, exhausting resources.
80/tcp	CSRF	MEDIUM	CSRF vulnerabilities found in DVWA and Mutillidae login/form pages.
80/tcp	Info Exposure	MEDIUM	phpMyAdmin, phpinfo.php, /tikiwiki/, /doc/, /icons/ all publicly accessible.
80/tcp	HTTP TRACE	LOW	TRACE method enabled — can be used for cross-site tracing (XST) attacks.
1099/tcp	RMI RCE	HIGH	RMI registry default config allows loading remote classes — remote code execution possible.
5432/tcp	CVE-2014-0224	HIGH	CCS Injection — OpenSSL MitM vulnerability allows session hijacking via crafted TLS handshake.
5432/tcp	CVE-2014-3566	HIGH	SSL POODLE also affects PostgreSQL — same CBC padding oracle vulnerability.

Port	CVE / ID	Severity	Description
6667/tcp	IRC Backdoor	CRITICAL	UnrealIRCd trojaned version detected — provides unauthorized remote access.
8180/tcp	HTTPOnly Missing	MEDIUM	JSESSIONID cookie missing HTTPOnly flag across all admin pages — session hijacking risk.
8180/tcp	Admin Exposed	HIGH	Apache Tomcat manager panel exposed at /manager/html — file upload possible if authenticated.
1524/tcp	Root Bindshell	CRITICAL	Port 1524 is a pre-configured root shell — direct root access without authentication.
23/tcp	Telnet	CRITICAL	Telnet transmits all data including credentials in plaintext — trivial to intercept.
512/tcp	rexecd	HIGH	Remote execution service — allows command execution without strong authentication.
513/tcp	rlogind	HIGH	Remote login service — weak authentication, allows unauthorized access.
514/tcp	rshd	HIGH	Remote shell daemon — no encryption, credentials sent in plaintext.

3.3 — Full Port Scan Summary (all 65,535 ports)

Total open ports: 30 | Closed: 65,505 | Filtered: 0

Port	Service	Port	Service	Port	Service
21	ftp	513	login	6000	X11
22	ssh	514	shell	6667	irc (backdoor)
23	telnet	1099	java-rmi	6697	ircs-u
25	smtp	1524	bindshell	8009	ajp13
53	domain	2049	nfs	8180	http (tomcat)
80	http	2121	ftp	8787	msgsrvr
111	rpcbind	3306	mysql	34958	unknown
139	netbios	3632	distccd	35594	unknown
445	smb	5432	postgresql	54671	unknown
512	exec	5900	vnc	57249	unknown

4. RISK SUMMARY

Severity	Count	Examples
CRITICAL	4	vsftpd backdoor, Bindshell (1524), UnrealIRCd backdoor, Telnet
HIGH	12	rsh/rexec/rlogin, Apache RCE risk, RMI RCE, CCS Injection, POODLE, Logjam
MEDIUM	7	CSRF, SMTP config, BIND 9.4.2, RPCbind, X11, phpMyAdmin exposed
LOW	1	HTTP TRACE enabled
TOTAL	24	Vulnerabilities identified across 30 open ports

5. RECOMMENDATIONS

• CRITICAL — Remove vsftpd 2.3.4 immediately

This version contains a known backdoor (CVE-2011-2523) that grants root access. Replace with a modern FTP server or disable FTP entirely and use SFTP.

- **CRITICAL — Close port 1524 (root bindshell)**

This port provides unauthenticated root shell access. It must be closed immediately via firewall rules.

- **CRITICAL — Remove UnrealIRCd**

The IRC daemon on port 6667 is a trojaned version with a built-in backdoor. Remove it completely.

- **CRITICAL — Disable Telnet (port 23)**

Telnet sends all data in plaintext. Disable it and use SSH exclusively for remote access.

- **HIGH — Upgrade OpenSSL / fix TLS configuration**

Resolve CVE-2014-3566 (POODLE), CVE-2015-4000 (Logjam), and CVE-2014-0224 (CCS Injection) by upgrading OpenSSL and disabling SSLv3 and export-grade ciphers.

- **HIGH — Disable r-services (ports 512, 513, 514)**

rexec, rlogin, and rsh use no encryption and weak authentication. Disable all three immediately.

- **HIGH — Restrict RMI registry (port 1099)**

Default RMI config allows remote class loading leading to RCE. Restrict with a SecurityManager and firewall the port.

- **HIGH — Secure Apache Tomcat (port 8180)**

Restrict access to /manager/html, set HTTPOnly on all cookies, and upgrade to a supported Tomcat version.

- **MEDIUM — Remove phpMyAdmin and phpinfo.php from public access**

These expose sensitive database and server configuration information. Restrict to localhost or remove entirely.

- **MEDIUM — Implement firewall rules**

Only expose ports that are required. All 30 open ports should be reviewed and unnecessary ones firewalled.

- **MEDIUM — Upgrade all services**

Apache 2.2.8, MySQL 5.0, PostgreSQL 8.3, BIND 9.4.2, and ProFTPD 1.3.1 are all end-of-life. Upgrade to current supported versions.

- **GENERAL — Schedule regular scans**

Run Nmap vulnerability scans on a regular schedule to detect newly discovered CVEs against running services.